

TASK 01 REPORT

INTERSHIP
CYBERSECURITY

20
25

Week 1: Security Assessment Report

1. Application Setup

During Week 1, I set up a mock web-based application downloaded from GitHub to perform cybersecurity testing. The setup steps included:

- Installing necessary packages
- Running the server locally
- Accessing the application on `http://localhost:3000`
- Exploring key pages such as **Signup**, **Login**, and **Profile**

This created a functional testing environment to identify and analyze security vulnerabilities.

2. Vulnerability Assessment

Tools Used:

- **OWASP ZAP** for automated vulnerability scanning
- **Browser Developer Tools** for manual testing
- Input-based tests such as:
 - XSS payloads
 - SQL injection attempts

Vulnerabilities Identified:

1. **Cookies Missing SameSite Attribute**
 - Could lead to Cross-Site Request Forgery (CSRF)
2. **Content Security Policy (CSP) Header Not Set**
 - Increases risk of XSS or injection attacks
3. **X-Content-Type-Options Header Missing**
 - May allow browsers to incorrectly interpret files, leading to XSS risks
4. **X-Frame-Options Header Not Set**
 - Leaves the application vulnerable to clickjacking attacks
5. **Suspicious Developer Comments**
 - Comments in the code may expose internal logic or sensitive information

6. Server Leaks Version Information

- Revealing server version makes it easier for attackers to exploit known vulnerabilities

3. Areas of Improvement

- Configure cookies to include the SameSite attribute for better CSRF protection
- Add a Content Security Policy header to reduce XSS and injection threats
- Set essential HTTP headers like X-Content-Type-Options and X-Frame-Options
- Remove or hide unnecessary comments in the source code to avoid information leakage
- Hide or disable server version information in HTTP response headers